# Risicobeoordeling & Behandelingsplan

**ISO 27001:2022 — Clause 6.1.2, 6.1.3, 8.2, 8.3**

| | |
|---|---|
| **Documentnummer** | ISMS-005 |
| **Versie** | 1.0 |
| **Classificatie** | Vertrouwelijk |
| **Eigenaar** | [Naam CISO / Verantwoordelijke] |
| **Goedgekeurd door** | [Naam Directie] |
| **Datum goedkeuring** | [DD-MM-JJJJ] |
| **Volgende review** | [DD-MM-JJJJ] |

## 1. Doel

Dit document beschrijft de methodiek die [Organisatienaam] hanteert voor het identificeren, beoordelen en behandelen van informatiebeveiligingsrisico's. Het bevat tevens het risicoregister en het risicobehandelingsplan.

## 2. Methodiek

### 2.1 Risicobeoordeling proces

```
Identificatie → Analyse → Evaluatie → Behandeling → Monitoring
```

1. **Identificatie:** Dreigingen, kwetsbaarheden en mogelijke gevolgen per informatie-asset
2. **Analyse:** Inschatting van waarschijnlijkheid en impact
3. **Evaluatie:** Vergelijking met acceptatiecriteria
4. **Behandeling:** Keuze uit behandelingsopties
5. **Monitoring:** Periodieke herbeoordeling

### 2.2 Waarschijnlijkheid

| Score | Niveau | Beschrijving |
|---|---|---|
| 1 | Zeer laag | Komt minder dan 1x per 5 jaar voor |
| 2 | Laag | Komt minder dan 1x per jaar voor |

| | | |
|---|---|---|
| 3 | Midden | Komt 1-3x per jaar voor |
| 4 | Hoog | Komt maandelijks voor |
| 5 | Zeer hoog | Komt wekelijks of vaker voor |

## 2.3 Impact

| Score | Niveau | Vertrouwelijkheid | Integriteit | Beschikbaarheid |
|---|---|---|---|---|
| 1 | Verwaarloosbaar | Geen gevoelige data gelekt | Geen merkbare gevolgen | < 1 uur uitval |
| 2 | Laag | Beperkte interne data gelekt | Kleine fout, snel corrigeerbaar | 1-4 uur uitval |
| 3 | Midden | Persoonsgegevens of klantdata gelekt | Significant onjuiste data | 4-24 uur uitval |
| 4 | Hoog | Grote hoeveelheid gevoelige data gelekt | Verlies van data-integriteit | 1-7 dagen uitval |
| 5 | Zeer hoog | Massaal datalek met juridische gevolgen | Onomkeerbaar dataverlies | > 7 dagen uitval |

## 2.4 Risicomatrix

| | Impact 1 | Impact 2 | Impact 3 | Impact 4 | Impact 5 |
|---|---|---|---|---|---|
| **Waarschijnlijkheid 5** | 5 (M) | 10 (M) | 15 (H) | 20 (H) | 25 (K) |
| **Waarschijnlijkheid 4** | 4 (L) | 8 (M) | 12 (H) | 16 (H) | 20 (H) |
| **Waarschijnlijkheid 3** | 3 (L) | 6 (M) | 9 (M) | 12 (H) | 15 (H) |
| **Waarschijnlijkheid 2** | 2 (L) | 4 (L) | 6 (M) | 8 (M) | 10 (M) |
| **Waarschijnlijkheid 1** | 1 (L) | 2 (L) | 3 (L) | 4 (L) | 5 (M) |

*L = Laag (acceptabel) · M = Midden (behandeling overwegen) · H = Hoog (behandeling vereist) · K = Kritiek (onmiddellijke actie)*

## 2.5 Risicobereidheid (Risk Appetite)

| Risiconiveau | Score | Behandeling |
|---|---|---|
| Laag (1-4) | Acceptabel | Geen aanvullende maatregelen vereist. Monitoring. |
| Midden (5-10) | Aandacht | Behandeling overwegen. Beslissing door CISO. |

| | | |
|---|---|---|
| Hoog (11-16) | Behandeling vereist | Maatregelen verplicht. Goedkeuring CISO. |
| Kritiek (17-25) | Onmiddellijke actie | Escalatie naar directie. Onmiddellijke maatregelen. |

### 2.6 Behandelingsopties

| Optie | Beschrijving | Voorbeeld |
|---|---|---|
| **Mitigeren** | Maatregelen implementeren om waarschijnlijkheid of impact te verlagen | Implementatie MFA, encryptie |
| **Overdragen** | Risico overdragen aan een derde partij | Cyberverzekering, outsourcing |
| **Vermijden** | Activiteit die het risico veroorzaakt stopzetten | Dienst uitfaseren |
| **Accepteren** | Risico bewust accepteren (binnen risk appetite) | Directie tekent af |

## 3. Risicoregister

| ID | Asset / Proces | Dreiging | Kwetsbaarheid | W | I | Score | Niveau | Behandeling | Maatre |
|---|---|---|---|---|---|---|---|---|---|
| R-001 | [Asset] | [Dreiging] | [Kwetsbaarheid] | [1-5] | [1-5] | [WxI] | [L/M/H/K] | [Mitigeren/ Overdragen/ Vermijden/ Accepteren] | [Beschr maatre |
| R-002 | | | | | | | | | |
| R-003 | | | | | | | | | |

**Voorbeelden ter inspiratie:**

| ID | Asset / Proces | Dreiging | Kwetsbaarheid | W | I | Score | Niveau | Behandel |
|---|---|---|---|---|---|---|---|---|
| R-001 | E-mailsysteem | Phishing | Onvoldoende bewustwording | 4 | 3 | 12 | H | Mitigeren |
| R-002 | Klantdatabase | Ransomware | Ontbrekende offline backups | 3 | 5 | 15 | H | Mitigeren |
| R-003 | Werkstations | Diefstal | Geen schijfversleuteling | 2 | 4 | 8 | M | Mitigeren |

| | | | | | | | | |
|---|---|---|---|---|---|---|---|---|
| R-004 | Cloud-omgeving | Ongeautoriseerde toegang | Geen MFA | 3 | 4 | 12 | H | Mitigeren |
| R-005 | Bedrijfscontinuïteit | Langdurige uitval | Geen getest BCP | 2 | 5 | 10 | M | Mitigeren |

## 4. Frequentie

| Activiteit | Frequentie |
|---|---|
| Volledige risicobeoordeling | Minimaal jaarlijks |
| Herbeoordeling na incident | Binnen 2 weken na significant incident |
| Herbeoordeling na wijziging | Bij significante wijzigingen in scope, technologie of organisatie |
| Monitoring restrisico's | Kwartaallijks |
| Rapportage aan directie | Bij managementreview (minimaal jaarlijks) |

## 5. Versiebeheer

| Versie | Datum | Wijziging | Auteur |
|---|---|---|---|
| 1.0 | [DD-MM-JJJJ] | Initiële versie | [Naam] |